

1-AfricanFalls

Lab: [AfricanFalls]

Contexto

Plataforma: [CyberDefenders] | **OS:** [Linux / Windows] | **Nivel:** [Medio]

Adquisición de memoria no volátil: [Análisis de partición lógica de disco]

Lista de Tareas

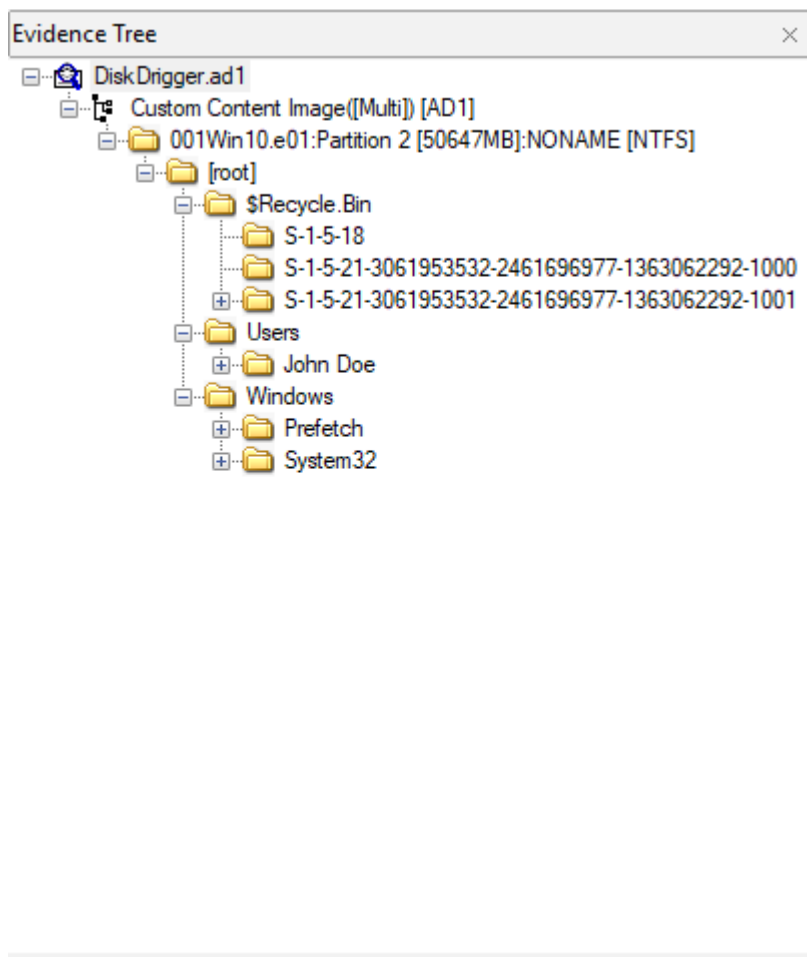
☐ 1. Verificamos todo el contenido disponible en el ctf

Encontramos 2 archivos dentro de la carpeta de descargas.

Nombre	Fecha de modificación	Tipo	Tamaño
 DiskDrigger	15/06/2021 5:33 a. m.	Archivo AD1	703.335 KB
 DiskDrigger.ad1	15/06/2021 5:33 a. m.	Documento de te...	10 KB

Usamos la herramienta FTK Imager para analizar el archivo .AD1 y abrimos el txt para ver que encontramos dentro.

Encontramos unos directorios en donde podremos investigar que estaba haciendo el presunto sospechoso.



Y encontramos esto dentro del reporte de adquisición:

DiskDrigger.ad1: Bloc de notas
Archivo Edición Formato Ver Ayuda
Created By AccessData® FTK® Imager 4.5.0.3

Case Information:
Acquired using: AD14.5.0.3
Case Number:
Evidence Number:
Unique Description:
Examiner:
Notes:

Information for D:\Users\Wawso3a\Desktop\DiskDrigger.ad1:
[Custom Content Sources]
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]\$Recycle.Bin*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]WindowsPrefetch*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]WindowsSystem32config*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeVideos*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeTemplates*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeStart Menu*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeSendTo*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeSearches*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeSaved Games*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeRecent*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePrintHood*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151510.jpg.qce(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151535.jpg.qce(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151642.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151804.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151826_HDR.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151858_HDR.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_151943.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152011.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152032_HDR.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152043.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152157.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152209.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152221.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152224.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContact20210429_152321.jpg(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContactC94C25598770A898 1.Shrd(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoePicturesContactC94C25598770A898 1.Shrd(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeOneDrive*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeNetHood*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeMy Documents*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeMusic*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeLocal Settings*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeLinks*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeFavorites*(Wildcard,Consider Case,Include Subdirectories)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeDownloadsdesktop.ini(Exact)
001Win10.e01:Partition 2 [50647MB]:NONAME [NTFS][root]UsersJohn DoeDownloads\$130(Exact)

Linea 1, columna 1 100% Windows (CRLF) UTF-8 con BOM

si bajamos un poco en el txt, encontramos el MD5 de la partición a analizar. Y con eso la respuesta a la

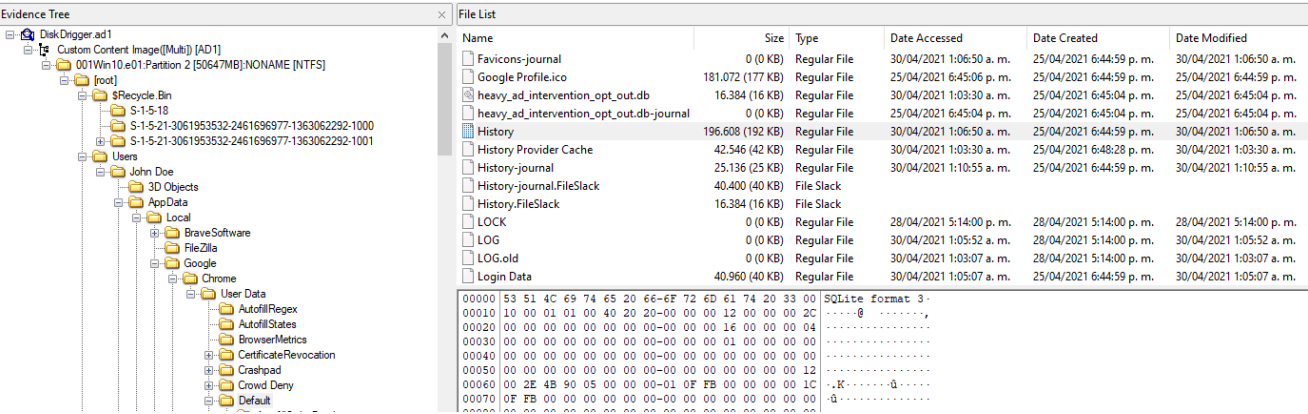
primera bandera.

```
[Computed Hashes]
MD5 checksum: 9471e69c95d8909ae60ddfff30d50ffa1
SHA1 checksum: 167aa08db25dfeeb876b0176ddc329a3d9f2803a
```

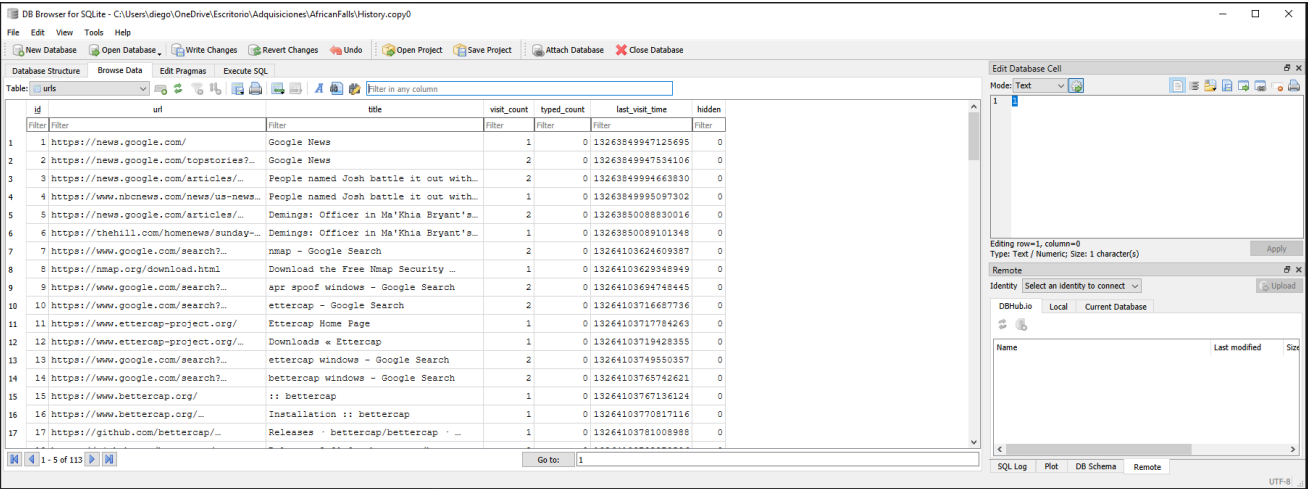
```
9471e69c95d8909ae60ddfff30d50ffa1
```

2. Verificación del historial de navegación.

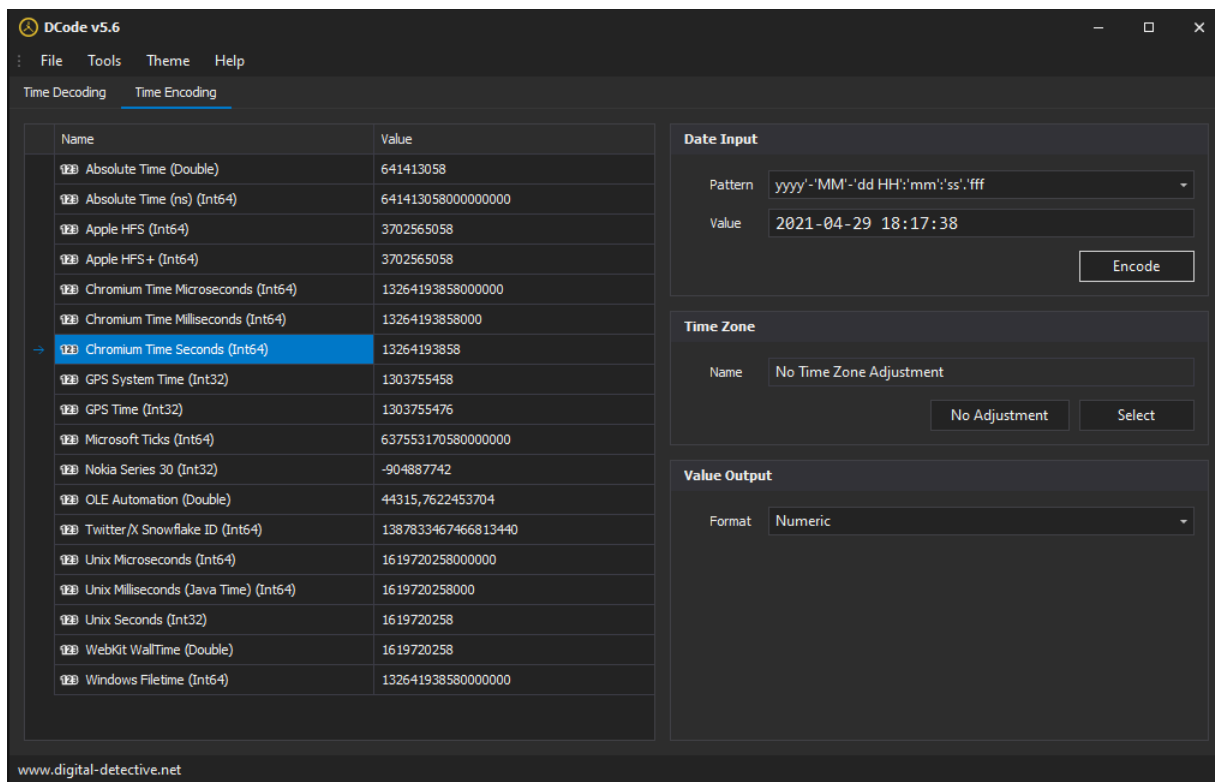
Dentro de la adquisición en FTK Imager, nos dirigimos a la siguiente ruta para obtener el archivo con el historial.



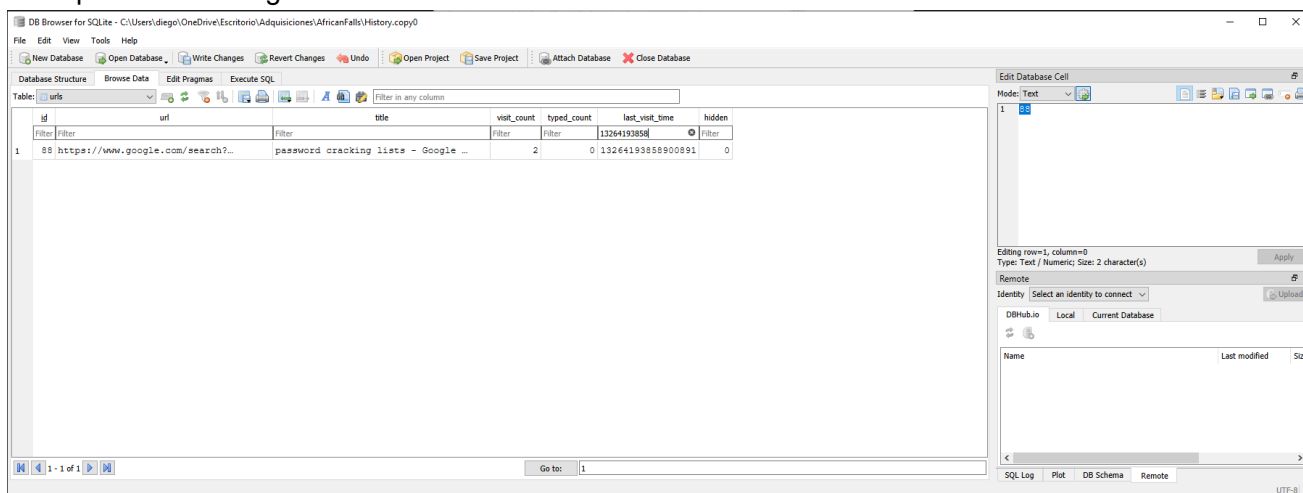
Descargamos el archivo para analizarlo con DB Browser:



Realizamos la conversión de la marca de tiempo 2021-04-29 18:17:38 a WebKit con Dcode:



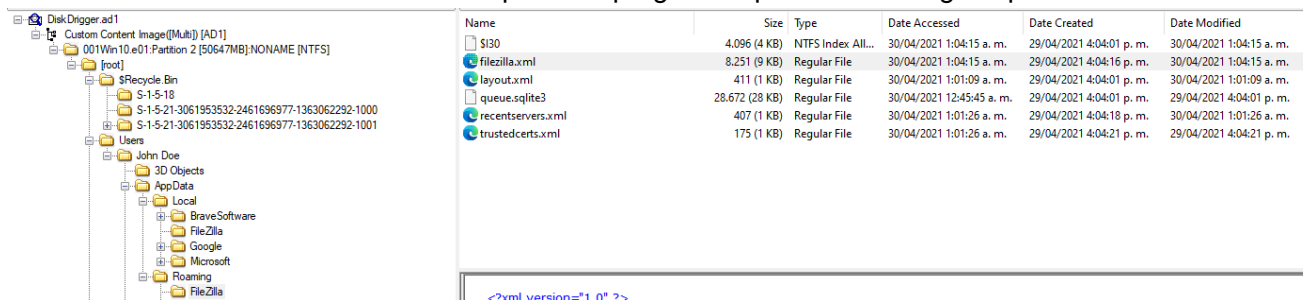
Nos genera el siguiente web kit: 13264193858, con esto filtramos dentro de DB Browser. Y encontramos la respuesta de la segunda bandera.



password cracking lists

3. Verificación de conexiones por FTP

Buscamos dentro de la ruta del usuario posibles programas para realizar algún tipo de conexión.



Dentro del contenido del archivo filezilla.xml encontramos la dirección ip a la que se conecto el

sospechoso, y con ello la respuesta a la tercera bandera.

```
1798869b0ccd9eadc93bbb43c4f14b462148c0606d5640186f82b6746fb
sig:8lCWReNLktzcxIS72z9pU25vk+jsiB6VDon8WbRFdEM3hVBfqax/aMX?
<Setting name="Kiosk mode">1</Setting>
<Setting name="Prompt password save">0</Setting>
<Setting name="Queue column widths">180 60 180 80 60 150</Setting>
<Setting name="Local filelist colwidths">170 80 120 120</Setting>
<Setting name="Remote filelist colwidths">150 75 80 100 80 85</Setting>
<Setting name="Splitter positions (v2)">97 -131 500000000 184 184 50000
<Setting name="Local filelist shown columns">1111</Setting>
<Setting name="Remote filelist shown columns">111111</Setting>
<Setting name="Local filelist column order">0,1,2,3</Setting>
<Setting name="Remote filelist column order">0,1,2,3,4,5</Setting>
<Setting name="Local filelist sortorder">0 0</Setting>
<Setting name="Remote filelist sortorder">0 0</Setting>
<Setting name="Site Manager position">0 421 204 804 443</Setting>
<Setting name="Window position and size">0 431 26 1184 732</Setting>
- <Setting name="Tab data" sensitive="1">
- <Tabs>
- <Tab connected="1" selected="1">
  <Host>192.168.1.20</Host>
  <Port>21</Port>
  <Protocol>0</Protocol>
  <Type>0</Type>
  <User>kali</User>
  <Logontype>2</Logontype>
  <PasvMode>MODE_DEFAULT</PasvMode>
  <EncodingType>Auto</EncodingType>
  <BypassProxy>0</BypassProxy>
  <Site />
  <RemotePath>1 0 4 home 4 kali 9 Documents</RemotePath>
  <LocalPath>C:\Users\John Doe\My Documents\</LocalPath>
</Tab>
</Tabs>
</Setting>
</Settings>
</FileZilla3>
```

192.168.1.20

- ☐ *4. Validamos en que fecha y hora se elimino una lista de contraseñas

Después de buscar por diferentes directorios del usuario encontramos una wordlist de contraseñas en la papelera.

Evidence Tree

DiskDrigger.ad1

Custom Content Image([Multi]) [AD1]

001Win10.e01:Partition 2 [50647MB].NONAME [NTFS]

[root]

\$Recycle.Bin

S-1-5-18

S-1-5-21-3061953532-2461696977-1363062292-1000

S-1-5-21-3061953532-2461696977-1363062292-1001

Users

John Doe

3D Objects

AppData

Contacts

Desktop

Documents

Downloads

Favorites

Links

Music

OneDrive

Pictures

Saved Games

Searches

Videos

Windows

Prefetch

ReadyBoot

System32

config

File List

Name	Size	Type	Date Accessed	Date Created	Date Modified
\$IW9Bj2Z.txt	158 (1 KB)	Regular File	30/04/2021 0:58:46	29/04/2021 18:22:17	29/04/2021 18:22:17
\$RW9Bj2Z.txt	754 (1 KB)	Regular File	29/04/2021 18:20:35	29/04/2021 18:19:55	29/04/2021 18:19:55
desktop.ini	129 (1 KB)	Regular File	30/04/2021 0:58:46	25/04/2021 17:58:11	25/04/2021 17:58:11

000

30 00 00 00 01 00 00 00-00 10 00 00 01 00 00 00

0...

010

10 00 00 00 68 01 00 00-68 01 00 00 00 00 00 00

...h...h...

020

BE 7A 01 00 00 00 06 00-70 00 5A 00 00 00 00 00

z.....p.Z.....

030

A8 76 01 00 00 00 02 00-BA DA 08 96 24 3D D7 01

v.....*0...\$=...

040

BA DA 08 96 24 3D D7 01-BA DA 08 96 24 3D D7 01

*0...\$=...*0...\$=...

050

5A DB 23 68 59 3D D7 01-A0 00 00 00 00 00 00 00

0hY=...

060

9E 00 00 00 00 00 00 00-20 00 00 00 00 00 00 00

.....

070

0C 03 24 00 49 00 57 00-39 00 42 00 4A 00 32 00

..\$-I-W-9-B-J-2-

080

5A 00 2E 00 74 00 78 00-74 00 00 00 00 00 00 00

Z...t-x-t-.....

090

6A 97 03 00 00 00 02 00-70 00 5A 00 00 00 00 00

j.....p.Z.....

0a0

A8 76 01 00 00 00 02 00-B9 5D 6C 41 24 3D D7 01

v.....*1h\$=...

0b0

DF 73 99 41 24 3D D7 01-0E 02 09 96 24 3D D7 01

B\$-A\$=...\$=...

0c0

40 7C 07 59 24 3D D7 01-00 10 00 00 00 00 00 00

8|-I\$=...

0d0

20 03 00 00 00 00 00 00-20 00 00 00 00 00 00 00

.....

Exportamos el archivo con los metadatos, en este caso el que inicia con una I en su nombre y usamos la herramienta Windows File Analyzer para ver detalles de su fecha de eliminación, y con esto la respuesta a la cuarta bandera.

Windows File Analyzer - [RBA - C:\Users\diego\OneDrive\Escritorio\Adquisiciones\AfricanFalls]

File Windows Help

Free to use for private, educational and non-commercial purposes

Recycle Bin Analysis

Path: C:\Users\diego\OneDrive\Escritorio\Adquisiciones\AfricanFalls

Volume serial: 6C39-5C3F

Volume label:

Report...

ID	Filename	Deleted	Size
W9Bj2Z	C:\Users\John Doe\Downloads\10-million-password-list-top-100.txt	29/04/2021 18:22:17	754

1 records

2021-04-29 18:22

☐ 5. Numero de ejecuciones del navegador Tor

Desde FTK Imager observamos que solo aparece el instalador de Tor, mas no se encuentra ningún rastro de ejecución, de Tor o Firefox, lo que nos quiere decir que el sospechoso, instalo el navegador

[illegible]

Name	Size	Type	Date Accessed	Date Created	Date Modified
☐ SVCHOST.EXE-EE1C9ACA.pf.FileSlack	2,370 (3 KB)	File Slack			
☒ SVCHOS-1.PF		\$30 INDEX Entry			
☒ SVCHOS-1.PF		\$30 INDEX Entry			
☐ SYMENUM.EXE-A56F0640.pf	43,982 (43 KB)	Regular File	30/04/2021 1:09:01	30/04/2021 1:09:01	30/04/2021 1:09:01
☐ SYSTEMSETTINGS.EXE-01072268.pf	61,534 (61 KB)	Regular File	29/04/2021 18:27:59	25/04/2021 18:08:24	29/04/2021 14:20:21
☐ SYSTEMSETTINGS.EXE-01072268.pf.FileSlack	4,002 (4 KB)	File Slack			
☐ SYSTEMSETTINGSBROKER.EXE-CBC37DFF.pf	12,747 (13 KB)	Regular File	29/04/2021 19:38:38	29/04/2021 19:38:38	29/04/2021 19:38:38
☐ SYSTEMSETTINGSBROKER.EXE-CBC37DFF.pf.FileSlack	3,637 (4 KB)	File Slack			
☐ TASKHOSTW.EXE-3E0874C8.pf	16,530 (17 KB)	Regular File	30/04/2021 1:15:09	25/04/2021 17:58:58	30/04/2021 1:15:09
☐ TASKHOSTW.EXE-3E0874C8.pf.FileSlack	3,950 (4 KB)	File Slack			
☐ TEXTINPUThost.EXE-18B298A2.pf	20,318 (20 KB)	Regular File	30/04/2021 1:01:01	25/04/2021 18:46:29	30/04/2021 1:01:01
☐ TEXTINPUThost.EXE-1D9E0D47.pf	20,639 (21 KB)	Regular File	29/04/2021 18:27:59	25/04/2021 17:52:03	25/04/2021 18:08:14
☐ TEXTINPUThost.EXE-1D9E0D47.pf.FileSlack	3,937 (4 KB)	File Slack			
☐ TIWORKER.EXE-E317E7F1.pf	16,087 (16 KB)	Regular File	30/04/2021 1:15:27	25/04/2021 18:16:57	30/04/2021 1:15:27
☒ TORBROWSER-INSTALL-WIN64-10.0-F3C4DF19.pf	26,581 (26 KB)	Regular File	29/04/2021 18:27:59	29/04/2021 18:22:32	29/04/2021 18:22:32
☐ TORBROWSER-INSTALL-WIN64-10.0-F3C4DF19.pf.FileSlack	2,091 (3 KB)	File Slack			
☐ TRUSTEDINSTALLER.EXE-3CC31E5.pf	4,189 (5 KB)	Regular File	30/04/2021 1:15:27	25/04/2021 17:52:02	30/04/2021 1:15:27
☐ TRUSTEDINSTALLER.EXE-3CC31E5.pf.FileSlack	4,003 (4 KB)	File Slack			
☐ UNINSTALL.EXE-21BE24FA.pf	8,335 (9 KB)	Regular File	29/04/2021 18:27:59	28/04/2021 17:28:14	28/04/2021 17:28:14
☐ UNINSTALL.EXE-21BE24FA.pf.FileSlack	3,953 (4 KB)	File Slack			

☐ **6. Verificación de la dirección de correo electrónico del sospechoso**

The screenshot displays the 'Evidence Tree' interface. At the top, a list of file system paths is shown: S-1-5-18, S-1-5-21-306195352 24616969771363062292:100, and S-1-5-21-306195352 24616969771363062292:100. Below this, the 'Users' folder is expanded, revealing 'John Doe'. Under 'John Doe', the 'AppData' folder is expanded, showing 'Local'. The 'Local' folder is further expanded, displaying 'BraveSoftware' and 'FileZilla'. The 'Google' folder is expanded, showing 'Chrome'. The 'Chrome' folder is expanded, showing 'User Data'. The 'User Data' folder is expanded, showing a list of subfolders and files: 'Autofill/Regex', 'Autofill/States', 'BrowserMetrics', 'CertificateRevocation', 'Crashpad', 'Crowd Deny', 'Default', 'FileTypePolicies', 'Floc', 'GrShaderCache', 'hyphen-data', 'MEIPreload', 'OnDeviceHeadSuggestMode', 'OriginTrials', 'pncal', 'RecoveryImproved', 'Safe Browsing', 'Safety Tips', 'ShadeCache', 'SSLErrorAssistant', 'SslResource Filter', 'SwReporter', 'ThirdPartyModuleList64', 'WidevineCdm', and 'ZxcvbnData'.

```
00000 53 51 4C 69 74 65 20 66-6F 72 6D 61 74 20 33 00 SQLite format 3-
00010 08 00 01 01 00 40 20 20-00 00 00 09 00 00 00 2C .....@ .....
00020 00 00 00 00 00 00 00 00-00 00 00 1D 00 00 00 04 .....

```

The screenshot shows the SQL Server Enterprise Manager interface. The 'Database Structure' pane on the left shows the 'logins' table. The table's columns are 'original_name', 'action_url', 'username_element', and 'username'. The 'username' column is highlighted. The table contains two rows: one with 'http://127.0.0.1/' and another with 'https://mail.protonmail.com/'.

URL	Title	Visit Time	Visit Count	Visited From	Visit Type	Visit Duration	Web B
https://github.com/danielmies...	SecLists/10-million-password-list-top-100.txt at master · danielmiessler/SecLists · ...	29/04/2021 18:18:47	6		Link	00:00:02.611	Chron
https://raw.githubusercontent.com/...		29/04/2021 18:18:49	1	https://github.com/dan...	Link		Chron
https://github.com/danielmies...		29/04/2021 18:18:49	1	https://github.com/dan...	Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-100.txt at master · danielmiessler/SecLists · ...	29/04/2021 18:18:54	6		Link		Chron
https://github.com/danielmies...	File Finder - GitHub	29/04/2021 18:19:16	2		Link		Chron
https://github.com/danielmies...		29/04/2021 18:19:17	2		Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-100.txt at master · danielmiessler/SecLists · ...	29/04/2021 18:19:20	6		Link		Chron
https://github.com/danielmies...	SecLists/Passwords/Common-Credentials at master · danielmiessler/SecLists · Git...	29/04/2021 18:19:22	4		Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-100.txt at master · danielmiessler/SecLists · ...	29/04/2021 18:19:45	6		Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-100.txt at master · danielmiessler/SecLists · ...	29/04/2021 18:19:45	6		Link		Chron
https://github.com/danielmies...	SecLists/Passwords/Common-Credentials at master · danielmiessler/SecLists · Git...	29/04/2021 18:19:58	4		Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-1000000.txt at master · danielmiessler/SecLi...	29/04/2021 18:20:05	3		Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-1000000.txt at master · danielmiessler/SecLi...	29/04/2021 18:20:05	3		Link	00:00:03.894	Chron
https://raw.githubusercontent.com/...		29/04/2021 18:20:09	1	https://github.com/dan...	Link		Chron
https://github.com/danielmies...		29/04/2021 18:20:09	1	https://github.com/dan...	Link		Chron
https://github.com/danielmies...	SecLists/10-million-password-list-top-1000000.txt at master · danielmiessler/SecLi...	29/04/2021 18:20:13	3		Link	01:21:04.053	Chron
http://youtube.com/	YouTube	29/04/2021 19:42:27	1		Typed URL		Chron
https://youtube.com/	YouTube	29/04/2021 19:42:27	1	http://youtube.com/	Typed URL		Chron
https://www.youtube.com/	YouTube	29/04/2021 19:42:27	1	https://youtube.com/	Typed URL	00:00:21.761	Chron
https://www.google.com/search...	7zip - Google Search	30/04/2021 1:02:56	2		Generated		Chron
https://www.google.com/search...	7zip - Google Search	30/04/2021 1:02:58	2		Link		Chron
https://www.7-zip.org/download...	Download	30/04/2021 1:02:58	1		Link	00:00:31.635	Chron
https://protonmail.com/	Secure email: ProtonMail is free encrypted email.	30/04/2021 1:04:32	1	http://protonmail.com/	Typed URL	00:00:46.142	Chron
https://protonmail.com/	Secure email: ProtonMail is free encrypted email.	30/04/2021 1:04:32	1		Typed URL		Chron
https://mail.protonmail.com/login...	Login ProtonMail	30/04/2021 1:04:37	1	https://protonmail.com/	Link		Chron
https://mail.protonmail.com/inbox...	Inbox dreammaker82@protonmail.com ProtonMail	30/04/2021 1:05:11	1	https://protonmail.com/	Link		Chron
https://mail.protonmail.com/inbox...	Inbox dreammaker82@protonmail.com ProtonMail	30/04/2021 1:05:18	1	https://protonmail.com/	Link		Chron
file:///C:/Users/John%20Doe/D...	almanac-start-a-garden.pdf	30/04/2021 1:05:57	1		Link	00:00:35.589	Chron
https://dfir.science/	Digital Forensic Science	30/04/2021 1:06:40	1	http://dfir.science/	Typed URL	00:00:06.275	Chron
https://dfir.science/	Digital Forensic Science	30/04/2021 1:06:40	1		Typed URL		Chron
https://dfir.science/2020/12/Ma...	Magnet CTF Week 8 - Persistence in plain sight - Digital Forensic Science	30/04/2021 1:06:46	1	https://dfir.science/	Link		Chron

Con BrowsingHistoryView observamos claramente la dirección de correo electrónico del sospechoso y con ello la respuesta de la sexta bandera.

dreammaker82@protonmail.com

☐ 7. Verificamos cual fue el dominio al que el sospechoso le realizo un escaneo

Dentro de FTK Imager nos dirigimos al apartado en donde powershell almacena el historial de comandos utilizados.

Evidence Tree

Disk Drigger ad1

Custom Content Image([Multi]) [AD1]

001Win10.e01-Partition 2 [50647MB]:NONAME [NTFS]

root

\$Recycle Bin

S-1-5-18

S-1-5-21-3061953532-2461696977-1363062292-1000

S-1-5-21-3061953532-2461696977-1363062292-1001

Users

John Doe

3D Objects

AppData

Local

BraveSoftware

FileZilla

Google

Chrome

User Data

CrashReports

Software Reporter Tool

Microsoft

Windows

Roaming

FileZilla

Microsoft

Windows

AccountPictures

CloudStore

Libraries

Network Shortcuts

PowerShell

PSReadLine

</

Dentro del historial de comandos utilizados encontramos un escaneo hacia un dominio, y con ello

encontramos la respuesta a la séptima bandera.

```
ping 10.0.2.2
exit
sdelete
ipconfig
ipconfig /cleardns
ipconfig /flushdns
exit
sdelete
exit
ipconfig /flushdns
ping dfir.science
nmap dfir.science
dir
cd .\Documents\
dir
sdelete .\accountNum
sdelete .\accountNum.zip
exit
cd E:\FTK_Imager_Lite_3.1.1
& '.\FTK_Imager.exe'
exit
```

dfir.science

☐ 8. Ubicación de donde se tomo la fotografía "20210429_152043.jpg"

Nos dirigimos a la ruta común en donde se almacenan las imágenes y encontramos la imagen solicitada, la descargamos y utilizamos la herramienta para acceder a sus metadatos.

Evidence Tree		File List					
		Name	Size	Type	Date Accessed	Date Created	Date Modified
Disk Drigger ad1	Custom Content Image([Multi]) (AD1)	\$130	4.096 (4 KB)	NTFS Index All...	30/04/2021 0:59:37	30/04/2021 0:18:36	30/04/2021 0:27:20
	001Win10e01.Partition 2 [50647MB]NONAME [NTFS]	20210429_151510.jpg.qce	4.510.260 (4....)	Regular File	30/04/2021 0:59:37	30/04/2021 0:27:20	30/04/2021 0:27:59
	[root]	20210429_151510.jpg.qce.FileSlack	3.532 (4 KB)	File Slack			
	\$Recycle Bin						
	S-1-S-18	20210429_151535.jpg	9.384.480 (9....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:31	29/04/2021 15:15:36
	S-1-S-21-3061953532-2461696977-1363062292-1000	20210429_151642.jpg	6.431.680 (6....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:31	29/04/2021 15:16:42
	S-1-S-21-3061953532-2461696977-1363062292-1001	20210429_151804.jpg	8.330.449 (8....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:27	29/04/2021 15:18:04
	Users	20210429_151826_HDR.jpg	5.326.213 (5....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:27	29/04/2021 15:18:26
	John Doe	20210429_151856_HDR.jpg	6.395.349 (6....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:28	29/04/2021 15:18:58
	3D Objects	20210429_151943.jpg	9.435.675 (9....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:28	29/04/2021 15:19:43
	AppData	20210429_152011.jpg	6.625.146 (6....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:28	29/04/2021 15:20:11
	Contacts	20210429_152032_HDR.jpg	6.755.615 (6....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:28	29/04/2021 15:20:32
	Desktop	20210429_152043.jpg	7.985.612 (7....)	Regular File	30/04/2021 0:27:04	30/04/2021 0:18:29	29/04/2021 15:33:46
	Documents	20210429_152157.jpg	8.018.266 (7....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:29	29/04/2021 15:21:57
	Downloads	20210429_152209.jpg	7.294.763 (7....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:29	29/04/2021 15:22:09
	Favorites	20210429_152221.jpg	7.190.696 (7....)	Regular File	30/04/2021 0:27:04	30/04/2021 0:18:30	29/04/2021 15:35:48
	Links	20210429_152224.jpg	7.775.223 (7....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:30	29/04/2021 15:22:24
	Music	20210429_152321.jpg	8.519.605 (8....)	Regular File	30/04/2021 0:18:46	30/04/2021 0:18:30	29/04/2021 15:23:21
	OneDrive	C94C25598770A89B 1.Shrd		\$130 INDEX Entry			
	Pictures	C94C255-1.SHR		\$130 INDEX Entry			
	Contact						
	Saved Games						
	Searches						
	Videos						

Utilizamos por medio de wsl.exe la herramienta de exiftool y sacamos la latitud y longitud de la ubicación

```
Megapixels      : 13.0
Shutter Speed   : 1/1419
Create Date     : 2021:04:29 15:20:43.367153
Date/Time Original : 2021:04:29 15:20:43.367153
Modify Date     : 2021:04:29 15:33:32.367153
Thumbnail Image : (Binary data 9000 bytes, use -b option to extract)
GPS Latitude    : 16 deg 0' 0.00" S
GPS Longitude   : 23 deg 0' 0.00" E
Focal Length    : 3.7 mm
GPS Position    : 16 deg 0' 0.00" S, 23 deg 0' 0.00" E
Light Value     : 13.7
```

Luego realizamos una búsqueda en Google con esas coordenadas y nos encuentra el sitio de donde fue tomada la foto.

Zambia

- ☐ *9. Investigamos cual es la ubicación principal anterior en donde se encontraba la imagen 20210429_151535.jpg*

Para realizar esta búsqueda debemos ir a FTK Imager y ubicar el ShellBag, posteriormente abriremos este archivo con ShellBag Explorer.

Name	Size	Type	Date Accessed	Date Created	Date Modified
GameExplorer	48 (1 KB)	Directory	25/04/2021 17:57:17	25/04/2021 17:57:17	7/12/2019 9:14:52
History	344 (1 KB)	Directory	30/04/2021 1:19:11	25/04/2021 17:57:17	25/04/2021 17:59:44
IECompatCache	136 (1 KB)	Directory	30/04/2021 0:33:18	25/04/2021 17:57:46	25/04/2021 17:57:46
IECompatUaCache	136 (1 KB)	Directory	30/04/2021 0:33:18	25/04/2021 17:57:46	25/04/2021 17:57:46
INetCache	536 (1 KB)	Directory	25/04/2021 17:57:46	25/04/2021 17:57:17	25/04/2021 17:57:46
INetCookies	56 (1 KB)	Directory	30/04/2021 1:19:11	25/04/2021 17:57:17	28/04/2021 17:44:19
Notifications	56 (1 KB)	Directory	30/04/2021 1:22:02	25/04/2021 17:57:45	25/04/2021 17:57:45
PowerShell	520 (1 KB)	Directory	30/04/2021 0:40:18	28/04/2021 17:17:40	28/04/2021 17:39:10
PPBCompatCache	136 (1 KB)	Directory	30/04/2021 0:33:18	25/04/2021 18:08:39	25/04/2021 18:08:39
PPBCompatUaCache	136 (1 KB)	Directory	30/04/2021 0:33:18	25/04/2021 18:08:39	25/04/2021 18:08:39
Ringtones	48 (1 KB)	Directory	25/04/2021 17:57:46	25/04/2021 17:57:46	25/04/2021 17:57:46
RoamingTiles	48 (1 KB)	Directory	25/04/2021 17:57:46	25/04/2021 17:57:46	25/04/2021 17:57:46
Safety	240 (1 KB)	Directory	25/04/2021 18:08:40	25/04/2021 17:57:49	25/04/2021 18:08:40
SettingsSync	48 (1 KB)	Directory	25/04/2021 17:58:58	25/04/2021 17:58:58	25/04/2021 17:58:58
Shell	280 (1 KB)	Directory	25/04/2021 17:57:17	25/04/2021 17:57:17	19/11/2020 2:53:31
Temporary Internet Files	264 (1 KB)	Reparse Point	25/04/2021 17:57:18	25/04/2021 17:57:18	25/04/2021 17:57:18
WebCache	56 (1 KB)	Directory	30/04/2021 0:58:46	25/04/2021 17:57:46	30/04/2021 0:47:02
WinX	336 (1 KB)	Directory	30/04/2021 1:20:50	25/04/2021 17:57:17	7/12/2019 9:14:52
\$I30	12,288 (12 KB)	NTFS Index All...	30/04/2021 1:12:43	25/04/2021 17:57:17	30/04/2021 1:12:43
UsrClass.dat	3,407.872 (3.32...)	Regular File	30/04/2021 0:59:57	25/04/2021 17:57:17	30/04/2021 0:59:57

Aquí podemos observar diferentes dispositivos que fueron conectados al equipo y que se navega en ellos y teniendo en cuenta el nombre de la imagen que estamos buscando podemos relacionar que fue tomada desde un dispositivo móvil, por su tipo de nombre y que del teléfono se arrastro o movió a la carpeta actual.

Value	Icon	Shell Type	MRU Position	Created On	Modified On	Accessed On	First Interacted	Last Interacted	Has Explorer
Internal storage	No im...	MTP storage	0					2021-04-29 20:54:22	☒

Name: E:
Absolute path: Desktop\My Computer\E:
Key-Value name path: BagMRU\1-3
Registry last write time: 2021-04-30 01:16:50.103

Miscellaneous
Shell type: Drive letter
Node slot: 20
MRU position: 0
of child bags: 2

Last interacted with: 2021-04-30 01:16:50.103

Summary Details Hex

Time zone: UTC 1 of 1 row visible (100,00 %)

Vemos que hay un dispositivo móvil, y que en su interior hay una carpeta con el nombre de la novena bandera.

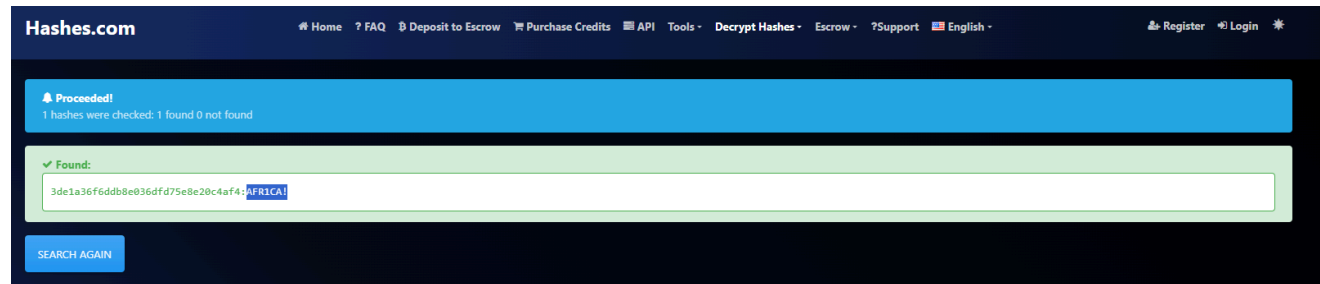
Camera

- ☐ 10. Descubrimos cual es la contraseña del usuario con hash:

Anon:1001:aad3b435b51404eeaad3b435b51404ee:3DE1A36F6DDB8E036DFD75E8E20C4AF4:::

Utilizaremos la herramienta web Hashes.com, después de separar el Hash NTLM, y con esto obtenemos

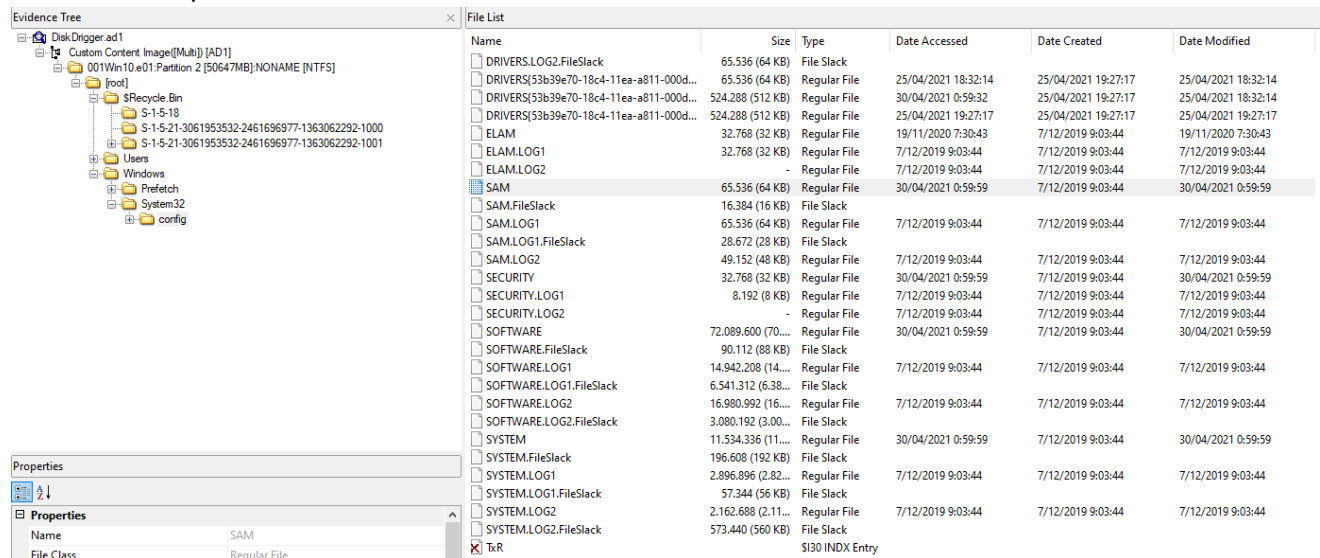
la contraseña de la decima bandera.



AFR1CA!

11. Descubrimos la contraseña del usuario Jhon Doe

Los primero que haremos será ir a FTK Imager, luego exportaremos el archivo SYSTEM Y SAM, con esos archivos podremos obtener el Hash NTLM del usuario de Windows.



Luego usando wsl.exe y con la herramienta Impacket, ejecutamos el siguiente comando para obtener el hash:

```
impacket-secretsdump -sam SAM -system SYSTEM LOCAL
```

```
└─$ impacket-secretsdump -sam SAM -system SYSTEM LOCAL
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xba508bdf20f883c63e72ad2c4d9f6fe2
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:69dbec1a98d4f53fbcc1b1fe5ce37c851:::
John Doe:1001:aad3b435b51404eeaad3b435b51404ee:ecf53750b76cc9a62057ca85ff4c850e:::
[*] Cleaning up...
```

Ahora usaremos la herramienta web de Hashes.com para obtener esa contraseña de inicio de Windows.

y con ello la ultima bandera de este ctf.

 **Proceeded!**
1 hashes were checked: 1 found 0 not found

 **Found:**
`ecf53750b76cc9a62057ca85ff4c850e:ctf2021`

SEARCH AGAIN

ctf2021

Lecciones Aprendidas & Blue Team

Concepto Nuevo: Herramientas antiguas (como `samdump2`) fallan al extraer contraseñas modernas de Windows y te engañan dándote un hash falso de "contraseña vacía" (`31d6cfe0...`). Hay que usar herramientas actualizadas como Impacket. También aprendí que los *ShellBags* registran qué carpetas abrí (incluso en un celular que ya desconecté), y que PowerShell guarda absolutamente todo lo que tecleo en un archivo de texto plano oculto.

- **Cómo Parcharlo (Fix): - Hashes:** Usar LAPS de Microsoft para rotar claves locales y un EDR para bloquear el acceso directo a los archivos SAM/SYSTEM.
 - **ShellBags:** Monitorear el acceso al archivo `UsrClass.dat` en el registro.
 - **PowerShell:** Activar el registro centralizado (Event ID 4104) para que el historial se envíe a un servidor seguro. Así, si el atacante borra su rastro local, la evidencia sobrevive.``